# How the Consiva Privacy Compliance Report is produced

A step-by-step explanation for a non-technical reader, based on the agent's code and one stored scan of gignaati.com (scan 277f3f37, 21 Oct 2026). Written for Sadaf. No code was changed to produce it.

## Read this first

Facts are labelled: Confirmed means read directly in the code or the stored scan. Inference means it follows from the code but was not tested. Unknown means the evidence does not say.

> No PDF file was attached. The numbers come from the report preview images and were checked against the stored scan and the scoring code. The new PDF generator itself has not been run yet.

> The DPDP Act's core notice and consent duties start about **13 May 2027**. Today is 22 Oct 2026. So every result here is **readiness for upcoming duties**, not a present violation.

## 1. How the website scan works

Confirmed One scan uses a real browser (Playwright) and makes three passes. The code is in `backend/app/scanner/crawler.py`.

| PASS | WHAT IT DOES | PAGES |
|---|---|---|
| **Before consent** | Loads the site and touches nothing. Records pages, forms, links, cookies and third-party requests. | Entered domain only, up to 5 pages |
| **After Accept** | Fresh browser. Finds and clicks an Accept control, waits, scrolls, records again. | **Homepage only** |
| **After Reject** | Fresh browser. Clicks a Reject control and records again. | **Homepage only** |

### How it finds and presses the buttons

- It tries the selectors of known consent tools first, then any clickable element whose text contains words like "accept all" or "reject all" ( `consent_interactor.py` ).
- It searches inside iframes too, because many consent tools render there.
- After a click it checks that the banner's control has disappeared. If it cannot confirm, the result is "unconfirmed". It never turns that into a failure.

**Example:** a site shows "Reject all". The scan clicks it, waits two seconds, then records what loads. If the banner is gone, the click counts as confirmed.

**Scope rule:** only the entered main domain is crawled, at most 5 pages ( `MAX_WEB_PAGES = 5` in `scan_profiles.py` ). Other sites are never crawled or listed.

## 2. How evidence is collected

Each number in the report is a count of something the scan observed. Nothing is estimated.

| REPORT ITEM | HOW IT IS COUNTED | CODE |
|---|---|---|
| Pages scanned (3 of 5) | Main-domain pages actually loaded. | `scan_profiles.py` |
| Third-party requests (13) | **Distinct third-party URLs with the query string removed.** It is not the number of network requests. A URL seen in several states is merged and counted in each state. | `tracker_detector.py` , `_merge_tracker_pass` |
| Analytics and marketing (5) | Those URLs whose address matches a known vendor with category analytics or marketing. | `rules/tracker_catalog.py` |
| Cookies (2) | Cookies in the browser after each pass, merged by name, domain and path. | `cookie_detector.py` |
| Third-party domains (7) | Distinct registered domains in those URLs. | `reportVisual.ts` |
| Privacy, cookie, terms policy | A link on the same registered domain whose address or text contains "privacy", "cookie" or "terms". | `policy_detector.py` |
| Forms | HTML forms with their fields. The purpose is a keyword guess. | `form_detector.py` |
| Consent banner | A known consent-tool script or variable, otherwise clickable text such as "accept all". The vendor is named only when matched. | `consent_signal_detector.py` |

**Example:** `fonts.googleapis.com` is a third-party domain, classed "functional". `googletagmanager.com` is classed "analytics".

## 3. Consent states

The three states are Before Consent, After Accept and After Reject. Section 6 of the Act says consent must be a clear affirmative action, so the report compares what loads before and after each choice.

**gignaati.com result**

| OBSERVED | BEFORE | AFTER ACCEPT | AFTER REJECT |
|---|---|---|---|
| Cookies | 0 | 2 | 0 |
| Analytics and marketing URLs | 0 | 5 | 0 |
| All third-party URLs | 7 | 13 | 8 |

**How to read it:** nothing known to track appeared before consent or after Reject. All 5 tracking URLs and both cookies appeared only after Accept. The 7 URLs before consent were not classed as analytics or marketing.

> Inference The columns are not like-for-like. Before consent covers up to 5 pages. After Accept and After Reject cover the homepage only. See section 10.

## 4. Score and coverage

Confirmed The calculation is in `backend/app/scoring/dpdp_score.py` (`_block`, `_pct`). It is a proposed Consiva method, not a formula the law prescribes.

```
score % = points earned ÷ points assessed × 100
```

```
coverage % = weight of assessed checks ÷ weight of applicable checks × 100
```

- Every check has a fixed weight from 2 to 5.
- Met earns 100% of its weight. Partly met earns 50%. Not met earns 0%.
- A check that could not be tested ("Unable to Verify") is left out of the score and lowers coverage. It is never counted as passed.
- "Not applicable" checks (the four organisation-specific ones) are left out of both.
- The score is hidden ("Insufficient evidence") if fewer than 2 checks were assessed or coverage is under 30%.
- A caution is shown if coverage is under 50% or fewer than 4 checks were assessed.

### How to read the number

| RESULT | MEANING |
|---|---|
| High score, high coverage | Most of what a scan can test looks ready. |
| High score, low coverage | What was tested looks fine, but much was not tested. This is gignaati.com. |
| Low score | Tested checks failed. See the findings for which ones. |
| "Insufficient evidence" | Too little could be tested to give a number. |

## 5. Worked example: gignaati.com

| CHECK | WEIGHT | RESULT | EARNED |
|---|---|---|---|
| C1 No tracking before consent | 5 | Met | 5 |
| C2 Consent mechanism present | 4 | Met | 4 |
| C3 Reject honoured | 4 | Met | 4 |
| C4 Reject as easy as Accept | 4 | Could not verify | left out |
| C5 Choices per purpose | 2 | Could not verify | left out |
| N1 Privacy notice | 4 | Met | 4 |
| N2 Cookies disclosed | 2 | Partly met | 1 |
| R9, R14A, R14B (rights) | 2+3+3 | Could not verify | left out |
| S6, S7 (security, breach) | 3+3 | Could not verify | left out |
| X4, X8, X10, X13 (organisation-specific) | 10 | Not applicable | excluded |

**Score:** earned 5+4+4+4+1 = 18. Assessed weight 5+4+4+4+2 = 19. **18 ÷ 19 × 100 = 94.7%**

**Coverage:** applicable weight 19 + 6 + 8 + 6 = 39. Assessed weight 19. **19 ÷ 39 × 100 = 48.7%**

**Consent area:** 13 ÷ 13 = 100%, coverage 13 ÷ 19 = 68.4%. **Notice area:** 5 ÷ 6 = 83.3%, coverage 100%. Rights and Security: not assessed.

**Caution:** coverage is under 50%, so the score carries a caution. Status counts: 4 met, 1 partly met, 0 not met, 7 could not verify, 4 not applicable (16 in all).

For comparison, swaransoft.com in the same database scored 100% with 64.1% coverage (25 ÷ 39). Confirmed

## 6. The 16 checks: what each one needs

| CHECK | RULE IN THE CODE | DPDP REFERENCE IN THE CODE |
|---|---|---|
| C1 No tracking before consent | Met if no analytics or marketing item appeared before consent. Not met if one did. Partly met if only unclassified items did. | Act s.6(1), Rule 3 |
| C2 Consent mechanism | Needs a banner or consent tool where tracking exists. Not applicable if no tracking. | Act s.5(1), s.6(1) |
| C3 Reject honoured | Needs Reject clicked and confirmed, then no tracking after it. | Act s.6(1), 6(4), 6(6), Rule 3(c)(i) |
| C4 Reject as easy as Accept | Met only if a "reject all" option was recorded. | Act s.6(4), Rule 3(c)(i) |
| C5 Choices per purpose | Met if per-purpose choices were detected. | Act s.6(1), Rule 3(b)(ii) |
| N1 Privacy notice | Met if any privacy-policy link was found. | Act s.5(1), Rule 3(a), (b) |
| N2 Cookies disclosed | Met with a cookie-policy link. Partly met with only a privacy-policy link. | Act s.5(1), Rule 3(b)(i) |
| R9 Contact of DPO or person | **Always "Could not verify".** | Act s.8(9), Rule 9 |
| R14A Means to exercise rights | **Always "Could not verify".** | Act s.11–13, Rule 14(1) |
| R14B Grievance process (90 days) | **Always "Could not verify".** | Act s.8(10), s.13, Rule 14(3) |
| S6 Security safeguards | **Always "Could not verify".** | Act s.8(5), Rule 6 |
| S7 Breach intimation | **Always "Could not verify".** | Act s.8(6), Rule 7 |
| X4, X8, X10, X13 | Excluded unless the organisation declares it applies. The agent never guesses this. | Consent Manager, erasure, children, Significant Data Fiduciary |

Confirmed The five "always" checks use `_not_observable`. Their result does not depend on the site, even if it publishes a DPO contact or grievance page. The code notes that the scan "does not read policy text". The section numbers come from the code's mapping. The code itself says the Act's sub-section numbers should be checked against the statute, so have your legal team confirm them.

## 7. Findings, severity and recommended actions

| GROUP | RULE |
|---|---|
| **Confirmed Findings** | Not met or partly met on a duty already in force, with direct evidence. |
| **Future Readiness** | The same kind of gap, on a duty that starts later. |
| **Needs Human Review** | Evidence is ambiguous. Two fixed items always appear: which entity-specific duties apply, and that most duties are not yet in force. |
| **Unable to Verify** | The scan lacks the evidence. Neither passed nor failed. |

- **Severity** (High, Medium, Low) comes from the check's documented weight, but only for an in-force duty with high-confidence, direct evidence ( `severity_for` in `scoring/findings.py` ). Until 13 May 2027 no severity can appear. Gaps show as Future Readiness instead.
- **Evidence** on each finding lists what was observed, on which page, in which consent state.
- **Recommended actions** are fixed text per check. They are ordered: in force first, then Not met before Partly met, then heavier weight ( `build_remediation_plan` ). Confirmed The AI does not write them.
- The older AI and rule findings (R-001 and so on, with risk levels) still exist in the dashboard and are separate from this score.

**Example, gignaati.com:** "Cookies and trackers are disclosed" is Partly met. Tracking was seen and a general privacy policy exists, but no dedicated cookie policy link was found. It is Future Readiness, so it has no severity.

## 8. The other report elements

| ELEMENT | WHAT IT MEANS AND HOW IT IS PRODUCED | CAN THE AGENT VERIFY IT? |
|---|---|---|
| Privacy policy | A same-domain link containing "privacy". Only existence is checked. | Existence yes. Content no. |
| Consent banner | Detected from a consent-tool script or clickable wording. | Yes, if displayed to the scanner. Some tools show nothing in some regions. |
| Forms | Forms and their fields. Purpose is a keyword guess (for example, newsletter signup). | Existence yes. What happens to the data no. |
| Data rights | The checks are R9, R14A, R14B. | No. Always "Could not verify". |
| Security indicators | The checks are S6, S7. | No. Always "Could not verify". |
| Severity | See section 7. | Rated only when the duty is in force. |
| Evidence | The observation, page and consent state behind each result. | Yes. It is stored with the scan. |

Confirmed Automated website observation covers: banner, clicks, cookies, third-party URLs, policy links, forms. Anything about internal practice (security, breach handling, rights handling, grievance, data sharing, retention) needs company evidence or human and legal review.

## 9. DPDP, GDPR and CCPA

| FRAMEWORK | WHAT EXISTS IN THE CODE | WHAT IS MISSING |
|---|---|---|
| **DPDP** | 16 checks mapped to Act sections and Rules, with effective dates, weights and methodology version 1.5.0. | Legal review of the section numbers. |
| **GDPR** | **Nothing.** The word appears only in banner-detection keyword hints and a lookup-file column. | A requirement registry, legal mapping, weights, effective-date logic, tests. |
| **CCPA** | **Nothing.** Same. | The same, plus "Do Not Sell" and opt-out detection. |

The "Not assessed" GDPR and CCPA cards in the new report are accurate. A framework name in the report is not evidence that it is supported.

## 10. What could be wrong, in priority order

### High: a reader could be misled

1. **Coverage wording.** The design says "5 of 16 checks had enough evidence". The code's formula line says coverage counts "checks". Coverage is weighted (19 ÷ 39), and 16 includes 4 not-applicable checks. Confirmed
2. **The consent table is not like-for-like.** Before consent covers up to 5 pages. After Accept and After Reject cover the homepage only. "Requests" are distinct URLs. Confirmed
3. **The coverage ceiling is 64.1%.** The five business checks (weight 14 of 39) can never be assessed by a scan, so 48.7% should be read against a maximum of 25 ÷ 39. Confirmed
4. **N1 "Met" is thin.** It means a link containing "privacy" exists. The policy is not read, so the notice content required by Rule 3 is untested. A blog post whose address contains "privacy" could also count. Inference
5. **N2 "Partly met" depends on the word "cookie" in a link.** The Act does not require a document with that name. Confirmed
6. **C4 is "Could not verify" although Reject was clicked and confirmed.** The code only upgrades a recorded "no reject option". An unknown stays unknown, which lowers coverage. Inference

### Medium

7. **Google Tag Manager is classed as analytics by default.** A bare GTM script does not by itself prove tracking. Confirmed
8. **Open issue from the earlier audit.** A consent tool is loaded but its banner is not shown, and trackers fire before consent. C1 would then become a high-severity Confirmed finding after 13 May 2027, when it should be "Needs review".
9. **The score is not saved.** It is recomputed on each request with today's date, so the same scan can read differently later, especially severity.
10. **Tracker page attribution** records only the first page that saw a URL.

### Low

11. The bands (80, 60, 40) come from your scope document and have no legal basis.
12. The name "Compliance score" overstates a readiness measure.

## 11. Questions to settle before the report can be trusted

1. Should the rights and security checks stay fixed at "Could not verify", or should the agent read published policy and contact pages?
2. Should N1 check what the policy says, or is "a policy link exists" acceptable wording?
3. Should the consent table compare the same pages in all three states?
4. Should a confirmed Reject click count as evidence that a reject option exists (C4)?
5. Have the DPDP section numbers been reviewed by a lawyer?
6. Will GDPR and CCPA be added, or stay "Not assessed"?
7. Which name stays: "Compliance score" or "Readiness score"?